

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Кампания сбора учётных данных: полиморфный фиш-набор, мультиканальный эксфил и bulletproof-инфраструктура

Credential Phishing • PhaaS • Multi-channel Exfil • Compromised Sites • Androxxgh0st • Bulletproof

Параметр	Значение
Период	6–9 июля 2026 (три волны)
Классификация	Фишинг для кражи учётных данных (credential harvesting)
Уровень угрозы	ВЫСОКИЙ
Атрибуция	Общий фиш-набор / PhaaS; доставка через bulletproof-хостинг KPROHOST (AS214940)
Цель	Корпоративные почтовые ящики отслеживаемого домена (реквизиты цели скрыты)
Статус	Кампания активна; страницы на скомпрометированных сайтах, эксфил мультиканальный

1. Краткое заключение

С 6 по 9 июля 2026 года на корпоративные почтовые ящики отслеживаемого домена поступили как минимум три волны фишинговых писем, нацеленных на кражу учётных данных корпоративной почты. Волны объединены общим фиш-набором (phishing kit / PhaaS): спуфинг отправителя (сначала под бренд, затем под администратора собственного домена жертвы), провал SPF, размещение страниц сбора учётных данных на взломанных легитимных сайтах и маскировка ссылок через доверенные редиректы.

Ключевые особенности кампании, установленные при анализе извлечённой нагрузки: (1) фиш-набор полиморфен — встречены как минимум два разных варианта клиентской реализации с разной обфускацией; (2) эксфильтрация украденных данных мультиканальна и ротируется от сборки к сборке — подтверждены три независимых канала (сервис форм Formspark, Telegram-бот, PHP-бэкенд на стороннем домене); (3) доставка ведётся из кластера bulletproof-хостинга, который тем же инструментарием (AndroXgh0st) и взламывает сайты для размещения страниц.

Практический вывод: блокировка одного канала эксфильтрации или одного URL не прерывает сбор учётных данных — необходимо закрывать все каналы одновременно и отдельно инициировать разделение/бан ресурсов. Отчёт публикуется, чтобы защитники могли заблокировать индикаторы, а владельцы скомпрометированных сайтов — устранить компрометацию.

2. Обзор волн

Признак	Волна 1 (6 июл)	Волна 2 (7 июл)	Волна 3 (9 июл)
Приманка	American Express KYC	Админ собств. домена	Админ собств. домена
Тема	«Reminder: action needed»	«Unrecognized Login»	«Account Locked»
Отправитель	78[.]130[.]245[.]134	77[.]83[.]39[.]10	77[.]83[.]39[.]10
Инфраструктура	Взлом. MikroTik-роутер	KPROHOST AS214940	KPROHOST AS214940
Обфускация ссылки	t.co	google.com/url	is.gd
Вариант набора	Webmail-харвестер	Webmail-харвестер	cPanel/Roundcube-клон
Канал эксфила	Formspark	Formspark / Telegram	PHP-бэкенд

Отдельно зафиксирован признак массовой рассылки: в короткой ссылке волны 3 предзаполненный адрес относился к другому, не связанному с получателем ящику — то есть одни и те же ссылки переиспользуются по разным жертвам.

3. Нагрузка и фиш-набор

Страницы сбора учётных данных были извлечены (анонимно) и проанализированы. Это статические клоны веб-почты (не AiTM/reverse-proxy). Встречены два варианта обфускации: (а) HTML, собираемый через `document.write(unescape('%XX...'))` — вариант под «Webmail»; (б) многоуровневый загрузчик `base64` → `atob` → обфускатор строковых массивов (`javascript-obfuscator`) → `document.write` — вариант-клон интерфейса cPanel/Roundcube («Orange Webmail»).

Во всех вариантах форма содержит предзаполненное (только для чтения) поле `email` и поле `password`; часть версий реализует «двойной сбор» (первая отправка имитирует ошибку, чтобы отсеять опечатку). После кражи пользователь перенаправляется на реальный домен своего адреса, чтобы визит выглядел завершённым штатно. В одном из вариантов через открытый листинг директории оказался виден служебный PHP-каркас набора.

4. Мультиканальная эксфильтрация (ключевой вывод)

Украденные пары «логин/пароль» уходят не в один адрес. При анализе разных сборок подтверждены три независимых канала, которые ротируются:

- Сервис форм Formspark — клиентский `fetch POST (JSON)` на `hxxps://submit-form[.]com/<id>`; используется не менее трёх ротируемых `form ID` (подтверждён 4FJePSjAq).
- Telegram-бот — прямая отправка логина и пароля в бот (`username MoneyMustbot`) через `api.telegram.org`.
- PHP-бэкенд на стороннем домене — `hxxps://qilu-pharma[.]store/files/steph/rundcub/main[.]php` (вариант-клон Roundcube).

Поскольку канал выбирается сборкой и ротируется, отключение одного из них не останавливает сбор. Приоритет реагирования — закрыть все три канала синхронно (в т.ч. репорт Telegram-бота в Telegram) и заблокировать асет-хост набора `mxxhdjr[.]com`.

5. Инфраструктура и атрибуция

- Волна 1 отправлена со взломанного роутера MikroTik (резидентский адрес, Болгария).
- Волны 2–3 отправлены из bulletproof-хостинга KPROHOST LLC (AS214940, US, Frankfort KY; присутствует в Spamhaus ASN-DROP).
- Сайты для размещения страниц взломаны с помощью AndroXgh0st, эксплуатирующего известные уязвимости (все — в каталоге CISA KEV): CVE-2017-9841 (PHPUnit RCE), CVE-2021-41773 (Apache path traversal), CVE-2018-15133 (Laravel APP_KEY / десериализация).
- Скомпрометированные сайты являются добросовестными жертвами; один из них был заражён шире одного пути и обслуживал страницы с 22 июня, позднее исходный путь начал отдавать 404 (набор перенесён).

6. Индикаторы компрометации (IOC)

Значения обезврежены (defanged). Продакшн-версии — в дампах STIX 2.1 / MISP.

Тип	Значение	Контекст
IP	78[.]130[.]245[.]134	Взлом. MikroTik, Болгария (Coolbox); AbuseIPDB 47. Отправитель волны 1.
IP	77[.]83[.]39[.]10	KPROHOST AS214940, bulletproof; AbuseIPDB 100. Отправитель волн 2–3.
ASN	AS214940	KPROHOST LLC (US); bulletproof, Spamhaus ASN-DROP.
URL	hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html	Страница сбора (взлом. WordPress).
URL	hxxps://habitatcyprus[.]com/wp-includes/build/	Страница сбора (взлом. WordPress; путь позднее 404).
URL	hxxps://lavilifescience[.]com/authn/mail/login[.]html	Страница сбора (скомпром. сайт).
URL	hxxps://transtecexpress[.]com[.]br/sddcc/secure[.]html	Страница сбора волны 3 (клон Roundcube).
URL (эксфил)	hxxps://submit-form[.]com/4FJePSjAq	Formspark; ≥3 ротируемых form ID. Цель takedown.
URL (эксфил)	hxxps://qilu-pharma[.]store/files/steph/rundcub/main[.]php	PHP-бэкенд сбора учёток. Цель takedown.
Telegram	бот MoneyMustbot	Прямой слив логина/пароля в Telegram. Репорт в Telegram.
Хост	mxhdjr[.]com	Асет/стейджинг-хост набора («webmailorange»).
Редирект	hxxps://t[.]co/... , google[.]com/url?q= , hxxps://is[.]gd/...	Маскировка полезной ссылки; домены-редиректы целиком не

		блокировать.
--	--	--------------

6.1. MITRE ATT&CK

- T1566.002 — Phishing: Spearphishing Link
- T1656 — Impersonation
- T1190 — Exploit Public-Facing Application (Androxgh0st)
- T1584.004 — Compromise Infrastructure: Server

7. Рекомендации

- Закрыть ВСЕ каналы эксфильтрации синхронно: Formspark-формы, PHP-бэкенд qilu-pharma, Telegram-бот (репорт в Telegram) — блокировка одного канала неэффективна.
- Заблокировать отправляющие IP и AS214940 (KPROHOST) на почтовом шлюзе; заблокировать конкретные вредоносные URL и асет-хост mxhdjr[.]com.
- Скомпрометированные легитимные сайты — блокировать по URL, а не по домену; уведомить владельцев (проверить на следы Androxgh0st, закрыть CVE-2017-9841 / CVE-2021-41773 / CVE-2018-15133).
- Помечать входящую почту, где From использует собственный домен организации, но письмо пришло извне и не прошло SPF/DKIM/DMARC.
- Внедрить устойчивый к фишингу MFA (FIDO2); обучать пользователей не вводить учётные данные по ссылкам из писем.

TLP:CLEAR — Этот документ может распространяться без ограничений.